

UNIVERSITI KUALA LUMPUR	
CAMPUS	MALAYSIAN INSITUTE OF INFORMATION TECHNOLOGY
COURSE NAME	VULNERABILITY ANALYSIS
COURSE CODE	IKB21403

Lab Group : L01-B05

NAME : TUAN MUHAMMAD FARIS BIN TUAN ZUKIMAN

STUDENT ID : 52215225169

Complete Laboratory Report

Lab	Title	Focus
Lab 1	Foundation	Vulnerability Scanning & Identification
Lab 2	Core Analyst Skill	CVE Deep Dive & CWE Mapping
Lab 3	Real-World Scenario	Manual Validation — True/False Positive
Lab 4	Advanced	Risk Prioritization & Remediation Planning

LAB 1

Foundation

Vulnerability Scanning & Identification

1. Introduction

This report presents the findings of a vulnerability scan conducted as part of Lab 1 (Foundation). The objective is to perform a basic network vulnerability scan, identify the top vulnerabilities found, and understand how to interpret scan results including CVE identifiers and CVSS scores.

The scan was performed using Nessus Essentials on Metasploitable2 — an intentionally vulnerable Linux virtual machine designed for security training.

2. Scan Scope & Methodology

2.1 Scan Environment

Attacker Machine	Kali Linux (Virtual Machine)
Target Machine	Metasploitable2 (Virtual Machine)
Target IP Address	192.168.56.104
Network Type	Host-Only Network (VirtualBox)
Scan Tool	Nessus Essentials v10.12.0
Scan Policy	Basic Network Scan
Severity Base	CVSS v3.0
Scan Date	5 June 2026
Scan Duration	18 minutes (12:08 AM – 12:26 AM)
Total Vulnerabilities	70

2.2 Methodology

Steps performed:

- Verified network connectivity between Kali Linux and Metasploitable2 using ping and Nmap
- Configured Nessus Essentials with target IP (192.168.56.104)
- Launched Basic Network Scan using default scan policy
- Reviewed 70 vulnerabilities discovered after scan completion (18 minutes)
- Selected Top 5 vulnerabilities based on CVSS score and risk factor
- Researched each using CVE.org, NVD, and Nessus plugin details

2.3 Difference Between a Finding and Real Risk

A scanner finding does not automatically equal a real-world risk. Actual risk depends on:

- Exploitability: Can the vulnerability be exploited in this specific environment?
- Context: Is the service exposed to untrusted users or internal only?
- Compensating controls: Are firewalls, IDS/IPS, or other mitigations in place?
- False positives: Scanners may flag based on version numbers without confirming the actual condition.

3. Scan Results Summary

Severity	CVSS Range	Risk Level
Critical	9.0 – 10.0	Immediate action required
High	7.0 – 8.9	High priority remediation
Medium	4.0 – 6.9	Scheduled remediation
Low	0.1 – 3.9	Monitor and patch when possible
Informational	N/A	No direct risk, useful for context
TOTAL: 70	—	—

4. Top 5 Vulnerabilities

#	Vulnerability Name	CVE ID	CVSS v2	CVSS v3	Severity
1	VNC Server 'password' Password	N/A	10.0	N/A	Critical
2	Debian OpenSSH/OpenSSL Weak RNG	CVE-2008-0166	10.0	N/A	Critical
3	Bind Shell Backdoor Detection	N/A	10.0	9.8	Critical
4	Apache Tomcat Ghostcat (AJP)	CVE-2020-1938	7.5	9.8	Critical
5	Samba Badlock Vulnerability	CVE-2016-2118	6.8	7.5	High

4.1 VNC Server 'password' Password

Plugin ID	61708
CVE	N/A
CVSS v2	10.0 (Critical)
CVSS v3	N/A
Synopsis	VNC server secured with trivially weak password 'password'
Impact	Full unauthorized remote desktop access; attacker can execute arbitrary commands
Recommendation	Set strong VNC password (12+ chars). Consider disabling VNC and using SSH.

4.2 Debian OpenSSH/OpenSSL Weak RNG (CVE-2008-0166)

Plugin ID	32314
CVE	CVE-2008-0166
CVSS v2	10.0 (Critical)
CVSS v3	N/A
Synopsis	SSH host keys generated with broken OpenSSL RNG — only 32,768 possible key values
Impact	SSH private keys compromised; man-in-the-middle attacks; unauthorized SSH access
Recommendation	Regenerate all SSH host keys. Revoke and regenerate all user SSH keys. Upgrade OpenSSL.

4.3 Bind Shell Backdoor Detection

Plugin ID	51988
CVE	N/A
CVSS v2	10.0 (Critical)
CVSS v3	9.8 (Critical)
Synopsis	Bind shell listening on remote port — system likely compromised (vsftpd 2.3.4 backdoor)
Impact	Complete system compromise; interactive root shell with no authentication required
Recommendation	Isolate system. Investigate backdoor source. Rebuild from clean baseline.

4.4 Apache Tomcat AJP Ghostcat (CVE-2020-1938)

Plugin ID	134862
CVE	CVE-2020-1938
CVSS v2	7.5 (High)
CVSS v3	9.8 (Critical)
Synopsis	AJP connector allows unauthenticated file read from Tomcat web root; potential RCE via file upload
Impact	Sensitive file disclosure (credentials in config files); possible Remote Code Execution
Recommendation	Disable AJP connector in server.xml. Upgrade Tomcat to 9.0.31+ or 10.x.

4.5 Samba Badlock Vulnerability (CVE-2016-2118)

Plugin ID	90509
CVE	CVE-2016-2118
CVSS v2	6.8 (Medium)
CVSS v3	7.5 (High)
Synopsis	MITM attacker can downgrade authentication in SAMR/LSAD protocols, impersonating legitimate users
Impact	Unauthorized access to SAM database; read/modify user credentials and group policies
Recommendation	Upgrade Samba to 4.4.2+. Enable SMB signing. Restrict SMB access by IP.

5. Key Learnings

5.1 Difference Between Finding and Real Risk

A scanner is a tool that identifies potential weaknesses not a definitive risk assessment. Each finding must be contextualized by network exposure, authentication requirements, compensating controls, and actual exploit availability before being treated as a confirmed risk.

5.2 Why False Positives Exist

- Version-based detection: Vendor may have backported patches without changing version number
- Configuration-dependent vulnerabilities: Only present under specific settings not present on this system
- Service fingerprinting errors: Scanner misidentifies a service or version
- Network conditions: Packet loss or filtering causes incomplete scan results

6. Conclusion

The Nessus scan of Metasploitable2 revealed 70 vulnerabilities. The top 5 VNC weak password, OpenSSL weak RNG (CVE-2008-0166), Bind Shell backdoor, Apache Tomcat Ghostcat (CVE-2020-1938), and Samba Badlock (CVE-2016-2118) demonstrate a range of vulnerability classes from weak authentication to cryptographic weaknesses and backdoors. These findings provide the foundation for Labs 2, 3, and 4.

LAB 2

Core Analyst Skill

CVE Deep Dive & CWE Mapping

1. Introduction

Lab 2 performs a deep-dive analysis of the top 5 vulnerabilities from Lab 1. For each vulnerability, this report identifies the CVSS Base Score, Attack Vector, Privileges Required, CWE classification, and assesses exploitability within the Metasploitable2 environment.

Critical lesson: CVSS score does NOT equal actual business risk. Context, exposure, and compensating controls determine real-world risk.

2. Key Concept: CVSS vs Business Risk

CVSS Base Score limitations:

- Does not consider service exposure (internal vs internet-facing)
- Does not account for compensating controls (firewalls, WAF, IDS/IPS)
- Does not reflect asset criticality
- CVSS v2 and v3 can produce very different scores (e.g., Ghostcat: 7.5 v2 vs 9.8 v3)

3. CVE Deep Dive Analysis

3.1 VNC Server 'password' Password

Plugin ID	61708
CVE	N/A — Configuration weakness
CWE	CWE-521: Weak Password Requirements
CVSS v2 Score	10.0 (Critical)
CVSS v3 Score	N/A
CVSS v2 Vector	AV:N / AC:L / Au:N / C:C / I:C / A:C
Attack Vector	Network — exploitable remotely over TCP/IP
Attack Complexity	Low — no special conditions required
Privileges Required	None — no prior authentication needed
Exploitable in Lab?	YES — Nessus confirmed login with password 'password'

CVE Notes:

No CVE assigned configuration weakness, not a software flaw. CWE-521 applies because the system accepts a single dictionary word with no complexity enforcement or lockout policy.

3.2 Debian OpenSSH/OpenSSL Weak RNG (CVE-2008-0166)

Plugin ID	32314
CVE	CVE-2008-0166
NVD	https://nvd.nist.gov/vuln/detail/CVE-2008-0166

CWE	CWE-310: Cryptographic Issues
CVSS v2 Score	10.0 (Critical)
CVSS v3 Score	N/A (pre-v3)
CVSS v2 Vector	AV:N / AC:L / Au:N / C:C / I:C / A:C
Attack Vector	Network — remote exploitation of weak SSH keys
Attack Complexity	Low — only 32,768 possible key values; precomputable
Privileges Required	None
Exploitable in Lab?	YES — Metasploitable2 runs Ubuntu 8.04, directly affected

CVE Notes:

Debian maintainer removed entropy sources from OpenSSL RNG, seeding it with PID only (max 32,768 values). Complete database of all weak keys publicly available. Metasploit module 'debian_ssh_rsa_2048_x86' automates exploitation.

3.3 Bind Shell Backdoor Detection

Plugin ID	51988
CVE	N/A — Active backdoor
Related	vsftpd 2.3.4 backdoor (malicious code in source distribution)
CWE	CWE-912: Hidden Functionality
CVSS v2 Score	10.0 (Critical)
CVSS v3 Score	9.8 (Critical)
CVSS v3 Vector	AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H
Attack Vector	Network — direct TCP connection to backdoor port
Attack Complexity	Low — connect and type commands
Privileges Required	None
Exploitable in Lab?	YES — bind shell actively listening, zero authentication required

CVE Notes:

No CVE active backdoor detected. Sending FTP username ending with ':)' triggers root shell on port 6200. Metasploit module 'exploit/unix/ftp/vsftpd_234_backdoor' completes in seconds.

3.4 Apache Tomcat AJP Ghostcat (CVE-2020-1938)

Plugin ID	134862
CVE	CVE-2020-1938 / CVE-2020-1745
NVD	https://nvd.nist.gov/vuln/detail/CVE-2020-1938
CWE	CWE-285: Improper Authorization

CVSS v2 Score	7.5 (High)
CVSS v3 Score	9.8 (Critical)
CVSS v3 Vector	AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H
Attack Vector	Network — AJP port 8009 accessible over network
Attack Complexity	Low — automated exploit available
Privileges Required	None — unauthenticated
Exploitable in Lab?	YES — Tomcat 5.5 (EOL) with AJP on port 8009

CVE Notes:

Ghostcat (disclosed Feb 2020) — AJP connector lacks authorization allowing any attacker on port 8009 to read any file from Tomcat web root. CVSS v2 (7.5) underestimates severity vs CVSS v3 (9.8). Always prefer v3 for modern analysis.

3.5 Samba Badlock Vulnerability (CVE-2016-2118)

Plugin ID	90509
CVE	CVE-2016-2118
NVD	https://nvd.nist.gov/vuln/detail/CVE-2016-2118
CWE	CWE-757: Selection of Less-Secure Algorithm During Negotiation
CVSS v2 Score	6.8 (Medium)
CVSS v3 Score	7.5 (High)
CVSS v3 Vector	AV:N / AC:H / PR:N / UI:R / S:U / C:H / I:H / A:H
Attack Vector	Network — requires man-in-the-middle position
Attack Complexity	High — MITM position required (ARP spoofing etc.)
Privileges Required	None
Exploitable in Lab?	CONDITIONAL — MITM feasible via ARP spoofing in Host-Only network

CVE Notes:

SAMR and LSAD protocols fail to enforce authentication level negotiation. AC:H (High Complexity) and UI:R (User Interaction Required) significantly reduce real-world exploitability compared to other findings.

4. Vulnerability Comparison Summary

Vulnerability	CVE	CVSSv2	CVSSv3	Attack Vector	Priv Req.	CWE
VNC Weak Password	N/A	10.0	N/A	Network	None	CWE-521

Vulnerability	CVE	CVSSv2	CVSSv3	Attack Vector	Priv Req.	CWE
OpenSSL Weak RNG	CVE-2008-0166	10.0	N/A	Network	None	CWE-310
Bind Shell Backdoor	N/A	10.0	9.8	Network	None	CWE-912
Ghostcat AJP	CVE-2020-1938	7.5	9.8	Network	None	CWE-285
Samba Badlock	CVE-2016-2118	6.8	7.5	Network (MITM)	None	CWE-757

5. Conclusion

All five vulnerabilities are exploitable in Metasploitable2, four requiring zero authentication. Ghostcat demonstrates why CVSS v3 is preferred over v2 (7.5 vs 9.8). Badlock's AC:H requirement significantly limits practical exploitability. Two findings have no CVE yet represent immediately exploitable critical risks.

LAB 3

Real-World Scenario

Manual Validation — True/False Positive Analysis

1. Introduction

Lab 3 simulates a real-world analyst scenario: three scanner findings are manually validated to determine their true nature. This mirrors daily professional VA analyst work automated scanners report findings, but the analyst must verify each one before classifying it and recommending action.

Three scenarios evaluated:

- Scenario 1: SSL Weak Cipher
- Scenario 2: Open Port with No Authentication
- Scenario 3: Outdated Service

Key lesson: Blind reporting (submitting scanner output without validation) = bad analyst.

2. Classification Definitions

Classification	Definition	Analyst Action
True Positive	Real vulnerability that exists and is exploitable in this environment	Escalate for remediation based on severity
False Positive	Vulnerability reported by scanner that does not exist or is not exploitable	Document evidence, close finding, note reason
Accepted Risk	Real vulnerability but organization consciously accepts the risk	Document rationale, get risk owner sign-off

3. Scenario 1: SSL Weak Cipher

3.1 Scanner Finding

Nessus reported SSL Version 2 and 3 Protocol Detection (Plugin 20007, CVSS 3.7) potential weak SSL/TLS cipher suites or deprecated protocol versions.

3.2 Manual Validation

Command executed:

```
nmap --script ssl-enum-ciphers -p 443,8443 192.168.56.104
```

Output received:

```
PORT      STATE  SERVICE
443/tcp   closed https
8443/tcp   closed https-alt
```

3.3 Verdict: ACCEPTED RISK

3.4 Technical Justification

- Ports 443 and 8443 are CLOSED confirmed by Nmap
- No SSL/TLS service running on standard HTTPS ports
- Web service on port 80 runs plain HTTP (Apache/2.2.8), not HTTPS
- ssl-enum-ciphers returned no results no SSL service to enumerate

Classified as Accepted Risk (not False Positive) because Nessus Plugin 20007 may have detected SSL on other service ports during the full scan. The finding is contextually valid but not on standard HTTPS ports. In a real environment, all ports would need checking: `nmap --script ssl-enum-ciphers -p- target`.

4. Scenario 2: Open Port with No Authentication

4.1 Scanner Finding

Nessus reported Bind Shell Backdoor (port 1524) and Telnet service (port 23) accessible without authentication.

4.2 Manual Validation

Step 1 — Nmap port scan:

```
nmap -sV -p 21,23,25,80,8080,6200 192.168.56.104
23/tcp open  telnet  Linux telnetd
```

Step 2 — Full scan revealed:

```
1524/tcp open  bindshell  Metasploitable root shell
```

Step 3 — Direct Netcat connection to port 1524:

```
echo "id" | nc -w3 192.168.56.104 1524
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
```

4.3 Verdict: TRUE POSITIVE (CONFIRMED)

4.4 Technical Justification

- Port 1524 confirmed OPEN service identified as 'Metasploitable root shell'
- Netcat connection to port 1524 returned immediate root shell: uid=0(root) gid=0(root)
- Zero authentication presented shell access granted immediately
- Port 23 (Telnet) confirmed OPEN transmits credentials in plaintext

Irrefutable True Positive direct evidence of immediate root access with no prerequisites. This is the highest severity finding in the entire assessment.

5. Scenario 3: Outdated Service

5.1 Scanner Finding

Nessus reported multiple end-of-life services: Apache Tomcat <= 5.5.x (EOL), Ubuntu 8.04 (EOL), vsftpd 2.3.4 (known backdoor version), Apache 2.2.8, and PHP 5.2.4.

5.2 Manual Validation — Banner Grabbing

FTP banner:

```
nc -w3 192.168.56.104 21 → 220 (vsFTPd 2.3.4)
```

HTTP server banner:

```
curl -sI http://192.168.56.104 → Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10
```

SSH banner:

```
nc -w3 192.168.56.104 22 → SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

SMTP banner:

```
nc -w3 192.168.56.104 25 → 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

5.3 Outdated Service Analysis

Service	Detected Version	Current Version	Risk
vsftpd	2.3.4	3.0.5+	Contains intentional backdoor — Critical
Apache HTTPD	2.2.8	2.4.62+	EOL since 2018, multiple unpatched CVEs
OpenSSH	4.7p1	9.8+	Very outdated, vulnerable to CVE-2008-0166
PHP	5.2.4	8.3+	EOL since 2011, hundreds of known CVEs
MySQL	5.0.51a	8.4+	EOL, multiple privilege escalation CVEs
PostgreSQL	8.3.0	16.x+	EOL, no security patches available
Apache Tomcat	5.5.x	10.1+	EOL, vulnerable to Ghostcat CVE-2020-1938
Ubuntu OS	8.04 LTS	24.04 LTS	EOL since 2013, no patches since 2015

5.4 Verdict: TRUE POSITIVE

5.5 Technical Justification

- Banner grabbing directly confirmed every version reported by scanner not a false positive
- vsftpd 2.3.4 contains intentional backdoor confirmed exploitable in Scenario 2
- Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7p1 all confirmed via direct service responses
- Ubuntu 8.04 EOL since 2013 no OS-level security patches for over 10 years

All outdated services represent genuine, confirmed risks. EOL software receives no security patches, meaning every new CVE discovered post-EOL is permanently unpatched.

6. Findings Summary

Scenario	Finding	Verdict	Key Evidence
1 — SSL Weak Cipher	SSL v2/v3 weak ciphers	Accepted Risk	Port 443/8443 CLOSED — no HTTPS on standard ports
2 — Open Port No Auth	Bind shell + Telnet without authentication	True Positive	nc to port 1524 → uid=0(root) immediately
3 — Outdated Service	vsftpd 2.3.4, Apache 2.2.8, PHP 5.2.4, Ubuntu 8.04	True Positive	Banner grab confirmed exact versions; all EOL

7. Key Learnings

7.1 What Real VA Analysts Do

- Scanners generate findings analysts validate them before reporting
- False positive rates can be 20–40% in real environments
- Each Critical/High finding must be manually verified with evidence
- Analyst must explain clearly WHY a finding is True/False Positive

7.2 Blind Reporting = Bad Analyst

Submitting raw scanner output without validation wastes remediation resources, includes false positives, lacks contextual justification, and damages security team credibility. Example: SSL Weak Cipher could have been blindly escalated validation revealed no HTTPS service on standard ports.

8. Conclusion

- Scenario 1 (SSL): Accepted Risk no active HTTPS on standard ports; contextually valid
- Scenario 2 (Open Port): True Positive direct root shell obtained, irrefutable evidence
- Scenario 3 (Outdated): True Positive banner grab confirmed all versions; vsftpd 2.3.4 backdoor confirmed exploitable

Manual validation confirms: the most dangerous finding was not the highest CVSS it was port 1524, providing immediate root access with zero prerequisites.

LAB 4

Advanced

Risk Prioritization & Remediation Planning

1. Introduction

Lab 4 is the culmination of the vulnerability analysis lifecycle. Having identified (Lab 1), researched (Lab 2), and validated (Lab 3) vulnerabilities, this lab prioritizes them for remediation based on real-world risk factors.

Three tasks:

- Task 1: Rank 5 vulnerabilities by Exploitability, Impact, and Exposure
- Task 2: Create remediation priority list with timeframes
- Task 3: Explain why Medium CVSS can be more dangerous than High CVSS

2. Risk Scoring Framework

Each vulnerability is scored on three factors (1–10 each):

Factor	Definition	Scoring Guide
Exploitability	How easy is exploitation? Is working exploit available?	10 = confirmed root access, zero skill; 1 = theoretical, no exploit
Impact	Worst-case outcome if successfully exploited?	10 = full system compromise (root + all data); 1 = minimal impact
Exposure	How accessible is the service to attackers?	10 = open port, no auth; 1 = local only, multiple barriers

Total Risk Score = Exploitability + Impact + Exposure (max 30). Higher score = higher real-world priority.

3. Vulnerability Risk Scoring

Rank	Vulnerability	CVSS	Exploit. /10	Impact /10	Exposure /10	Total /30	Priority
1	Bind Shell Backdoor (Port 1524)	9.8	10	10	10	30	IMMEDIATE
2	VNC Weak Password (Port 5900)	10.0	10	9	9	28	IMMEDIATE
3	OpenSSL Weak RNG (CVE-2008-0166)	10.0	8	9	8	25	CRITICAL
4	Ghostcat AJP (CVE-2020-1938)	9.8	8	8	7	23	HIGH
5	Samba Badlock	7.5	5	7	6	18	MEDIUM

Rank	Vulnerability	CVSS	Exploit. /10	Impact /10	Exposure /10	Total /30	Priority
	(CVE-2016-2118)						

Note: VNC scores CVSS 10.0 (higher than Bind Shell's 9.8) but ranks 2nd because Bind Shell provides direct unauthenticated root command execution confirmed with uid=0(root) evidence from Lab 3.

4. Individual Scoring Justification

4.1 Rank #1 — Bind Shell Backdoor (Port 1524) | Score: 30/30

Factor	Score	Justification
Exploitability	10/10	Direct root shell confirmed in Lab 3 — zero authentication, zero skill. Netcat returned uid=0(root) immediately.
Impact	10/10	Complete system compromise: full read/write/execute as root. Attacker owns everything.
Exposure	10/10	Port 1524 open on network. Any attacker with network access can exploit instantly. No controls.

4.2 Rank #2 — VNC Weak Password (Port 5900) | Score: 28/30

Factor	Score	Justification
Exploitability	10/10	Scanner confirmed login with password 'password'. No skill required — any VNC client works.
Impact	9/10	Full remote desktop access. Slightly below Bind Shell as GUI access vs direct command shell.
Exposure	9/10	Port 5900 open. Graphical interface is highly accessible; slightly less stealthy than command shell.

4.3 Rank #3 — OpenSSL Weak RNG (CVE-2008-0166) | Score: 25/30

Factor	Score	Justification
Exploitability	8/10	Requires precomputed key database and Metasploit module. Straightforward but needs more setup than direct access.
Impact	9/10	Full SSH compromise — command execution, file access, credential theft. Systemic — affects all keys.
Exposure	8/10	SSH port 22 open. All SSH keys on Ubuntu 8.04 are weak. Exposure is systemic.

4.4 Rank #4 — Apache Tomcat Ghostcat (CVE-2020-1938) | Score: 23/30

Factor	Score	Justification
Exploitability	8/10	Metasploit module available. Requires AJP port 8009. File upload needed for full RCE.
Impact	8/10	File read of sensitive configs (credentials). Potential RCE. Slightly less direct than shell access.
Exposure	7/10	Port 8009 open. Tomcat 5.5 EOL. Less exposure than direct shell ports.

4.5 Rank #5 — Samba Badlock (CVE-2016-2118) | Score: 18/30

Factor	Score	Justification
Exploitability	5/10	Requires MITM position (ARP spoofing) AND legitimate user to initiate SMB. AC:H — significantly harder.
Impact	7/10	SAM database access — read/modify credentials. High impact in domain; lower in standalone lab.
Exposure	6/10	SMB ports 139/445 open but exploitation requires network MITM — not directly exploitable.

5. Remediation Priority List

Priority 1 — Immediate (Within 24 Hours)

#	Vulnerability	Action	Verify
1	Bind Shell Backdoor	Kill backdoor process. Block port 1524. Isolate system. Full forensic investigation.	nmap -p 1524 target → must show closed
2	VNC Weak Password	Set strong password (12+ chars, complex). Restrict VNC by IP or disable, use SSH.	Attempt login with 'password' → must fail

Priority 2 — Critical (Within 48 Hours)

#	Vulnerability	Action	Verify
3	OpenSSL Weak RNG (CVE-2008-0166)	Regenerate all SSH host keys. Revoke and regenerate all user keys. Upgrade OpenSSL.	ssh-keyscan target → verify new fingerprint

Priority 3 — High (Within 1 Week)

#	Vulnerability	Action	Verify
4	Ghostcat AJP (CVE-2020-1938)	Disable AJP connector in server.xml. Upgrade Tomcat to 9.0.31+ or 10.x.	nmap -p 8009 target → must show closed

Priority 4 — Medium (Within 2 Weeks)

#	Vulnerability	Action	Verify
5	Samba Badlock (CVE-2016-2118)	Upgrade Samba to 4.4.2+. Enable SMB signing (server signing = mandatory). Restrict by IP.	smbclient --version → confirm 4.4.2+

6. Why Medium CVSS Can Be More Dangerous Than High

6.1 Exposure Difference

	High CVSS (8.5) Vulnerability	Medium CVSS (6.5) Vulnerability
Example	RCE in internal HR system	SQL Injection in public login page
Exposure	Internal only — behind VPN, requires employee credentials	Internet-facing — any person on Earth can attempt exploitation
Real Risk	Attacker must breach perimeter AND get VPN credentials first	Exploitable from anywhere with no prerequisites
Verdict	Lower actual risk despite higher CVSS	Higher actual risk despite lower CVSS

6.2 Exploit Availability

	High CVSS (7.8) Vulnerability	Medium CVSS (5.5) Vulnerability
Example	Complex kernel vuln requiring specific race condition	Known SQL injection with public Metasploit module
Exploitability	Theoretical — no public exploit, advanced skills required	Automated — one command, exploitable by script kiddies
Real Risk	Only nation-state actors can exploit reliably	Any attacker with basic skills can exploit within minutes
Verdict	Lower actual risk despite higher CVSS	Higher actual risk despite lower CVSS

6.3 Asset Criticality

	High CVSS (8.0) Vulnerability	Medium CVSS (5.0) Vulnerability
Example	RCE on a test/dev server	Information disclosure on payment server
Asset Value	Dev server: no real data, disposable, no production access	Payment server: credit card data, PII, PCI DSS scope
Business Impact	Compromise: minor — rebuild in 1 hour, no breach	Any data leak: GDPR fines, PCI penalties, lawsuits
Verdict	Lower actual risk despite higher CVSS	Higher actual risk despite lower CVSS

6.4 Real Example From This Lab

Samba Badlock CVSS v3 = 7.5 (High). In this isolated lab with no real users or Active Directory, actual exploitability is low it requires MITM positioning and user interaction. A hypothetical Medium CVSS (5.5) information disclosure bug exposing credentials on a public-facing API would present far greater real-world risk in the same environment.

This is why EPSS (Exploit Prediction Scoring System) was developed it measures the probability a vulnerability will be exploited in the wild within 30 days, providing a more actionable metric than CVSS Base Score alone.

7. Final Remediation Summary

Rank	Vulnerability	CVSS	Risk /30	Priority	Timeframe
1	Bind Shell Backdoor (Port 1524)	9.8	30	IMMEDIATE	Within 24 hours
2	VNC Weak Password (Port 5900)	10.0	28	IMMEDIATE	Within 24 hours
3	OpenSSL Weak RNG (CVE-2008-0166)	10.0	25	CRITICAL	Within 48 hours
4	Ghostcat AJP (CVE-2020-1938)	9.8	23	HIGH	Within 1 week
5	Samba Badlock (CVE-2016-2118)	7.5	18	MEDIUM	Within 2 weeks